

Nom : WIDAMOU YANDA

NIVEAU : MASTER 2

FILIERE : SISD

EXERCICE IX : CHAPITRE 9

Ex. 9.1 Classification des Indicateurs

La CTI permet de passer d'une défense réactive (réponse aux alertes) à une défense proactive (anticipation basée sur la connaissance de l'attaquant)

Indicateur	Niveau CTI	Type	Justification
(a) sha256:3a7d4f8...	Technique	IoC	Empreinte figée d'un fichier malveillant (bas de la "Pyramide de la Douleur").
(b) powershell.exe -enc...	Tactique	IoA	Comportement suspect en temps réel (exécution de code obfusqué).
(c) Outil Mimikatz	Tactique	TTP	Méthode connue pour l'extraction de mots de passe.
(d) Campagne secteur Afrique	Stratégique	Menace	Analyse haut niveau du ciblage et de l'intention de l'attaquant.
(e) Domaine evil.io	Technique	IoC	Artefact réseau lié à l'infrastructure de commande (C2).

Ex. 9.2 Objet STIX

Le format STIX (Structured Threat Information eXpression) est le standard pour échanger des informations sur les menaces.

```
[
{
  "type": "indicator",
  "spec_version": "2.1",
  "id": "indicator--8e2d-48d1-93e1-456789abcdef",
  "created": "2026-05-09T14:00:00.000Z",
  "indicator_types": ["malicious-activity"],
  "pattern": "[domain-name:value = 'evil.io']",
  "pattern_type": "stix",
  "valid_from": "2026-04-12T00:00:00Z",
  "description": "Domaine C2 utilisé lors de l'incident LiZbiZ-SIS"
},
{
  "type": "relationship",
  "spec_version": "2.1",
  "id": "relationship--f47a-42d2-a2b1-1234567890ab",
  "relationship_type": "indicates",
  "source_ref": "indicator--8e2d-48d1-93e1-456789abcdef",
  "target_ref": "attack-pattern--bf333628-8255-492c-87d4-c9d23e23923e"
}
]
```

Ex. 9.3 Intégration SIEM (MISP vers Wazuh)

Pour que LiZbiZ-SIS puisse détecter automatiquement les menaces partagées par la communauté, il faut lier la base de connaissance **MISP** à l'outil de détection **Wazuh**.

1. **Script d'export** : Utiliser un script Python (via `PyMISP`) pour interroger l'API de MISP et extraire les attributs (IPs, domaines) marqués comme "IDS signature".
2. **Format CDB (Constant DataBase)** : Convertir ces indicateurs dans le format attendu par Wazuh :

- Exemple : `evil.io:malicious_domain`

3. **Processus Wazuh** :

- Déposer le fichier dans `/var/ossec/etc/lists/misp_indicators`.
- Déclarer la liste dans le fichier `ossec.conf`.

4. **Règle de détection** : Créer une règle personnalisée qui compare les logs (DNS ou Proxy) à cette liste :

```
<rule id="100050" level="10">
```

```
<list field="url" lookup="address_match_key">etc/lists/misp_indicators</list>
```

```
<description>Connexion vers un domaine malveillant identifié par MISP</description>
```

```
</rule>
```

5. **Alerte générée** : Wazuh déclenche une alerte de niveau 10 (Critique) dès qu'un employé ou un serveur tente d'accéder à un domaine présent dans la liste.
6. **Fréquence de mise à jour** : Recommandée toutes les **4 à 12 heures** (via une tâche Cron) pour rester à jour sans surcharger le moteur de règles.

EXERCICE X : CHAPITRE 10

Ex. 10.1 RETEX structuré : Incident LiZbiZ-SIS

1. **Résumé de l'incident** : Intrusion sur le serveur Web suivie d'un mouvement latéral vers l'ERP et d'une exfiltration de 50 000 dossiers clients le 12/04/2026.

2. **Chronologie des faits** : Détection du scan à 02:47, accès SSH à 03:14, mouvement SMB à 03:21, effacement des logs à 03:48.

3. **Analyse des écarts** : Délai de détection de 27 min jugé trop long ; absence de blocage automatique sur force brute SSH.

4. **Causes profondes (Les 5 Pourquoi)** :

- *Pourquoi l'exfiltration a eu lieu ?* Parce que l'attaquant a accédé au serveur ERP.
- *Pourquoi a-t-il accédé à l'ERP ?* Parce qu'il a rebondi depuis le serveur Web via SMB.
- *Pourquoi a-t-il pu rebondir ?* Parce qu'il n'y avait pas de segmentation réseau entre le Web et l'ERP.

- *Pourquoi n'y avait-il pas de segmentation ?* Parce que l'architecture a été déployée pour la rapidité sans audit de sécurité.
- *Pourquoi pas d'audit ?* **Cause racine :** Absence de politique de "Security by Design" dans le cycle de développement. **5. Impact :** Fuite de données (50k clients), coût technique 5M FCFA, risque de non-conformité Loi 2010/012. **6. Recommandations (Actions priorisées) :**
 1. **P0 :** Isoler le serveur Web du serveur ERP par un pare-feu interne (VLAN).
 2. **P0 :** Activer l'authentification multi-facteurs (MFA) sur tous les accès SSH/RDP.
 3. **P1 :** Déployer une règle de blocage automatique (Fail2Ban) après 3 échecs de connexion.
 4. **P1 :** Centraliser les logs en temps réel sur un serveur distant non modifiable.
 5. **P2 :** Organiser une sensibilisation au phishing pour le personnel.
 6. **P2 :** Planifier un test d'intrusion annuel.

Ex. 10.2 Tableau de couverture MITRE ATT&CK

Technique	Source de log requise	Règle SIEM ?	Action si non existante
T1595 (Scan)	Logs Firewall pfSense	Oui	N/A
T1110 (Brute Force)	Auth.log (SSH)	Oui	N/A
T1505.003 (Web Shell)	Logs Apache / Auditd	Non	Créer règle sur modification /var/www
T1021.002 (SMB Share)	Logs Security Windows	Oui	N/A
T1003 (Dump Creds)	Sysmon (EID 10)	Non	Installer Sysmon et configurer l'alerte
T1560 (Archive Data)	Commande zip/tar	Non	Activer monitoring des commandes Bash
T1070.001 (Clear Logs)	EID 1102 Windows	Oui	N/A

Ex. 10.3 Scénario Purple Team

L'exercice Purple Team réunit l'Attaque (Red) et la Défense (Blue) pour tester les angles morts identifiés ci-dessus.

Technique 1 : Web Shell (T1505.003)

- **Attaque :** Upload d'un fichier `test-shell.php` exécutant `whoami`.
- **Source attendue :** Logs d'accès Apache (Code 200 sur fichier inhabituel).
- **Action SIEM :** Créer une alerte Wazuh pour tout nouveau fichier `.php` créé par l'utilisateur `www-data`.

Technique 2 : OS Credential Dumping (T1003)

- **Attaque :** Exécution de `Mimikatz` en mémoire pour extraire les hashes NTLM.
- **Source attendue :** Sysmon Event ID 10 (`ProcessAccess` vers `lsass.exe`).
- **Action SIEM :** Vérifier que Sysmon remonte bien les accès suspect à la mémoire de `lsass`.

Technique 3 : Data Compressed (T1560)

- **Attaque :** Utilisation de `7zip` pour compresser un dossier contenant des fichiers factices `".pdf"`.

- **Source attendue :** Logs de ligne de commande (Process Creation).
- **Action SIEM :** Créer une règle corrélant la création d'une archive volumineuse suivie d'une connexion réseau sortante inhabituelle.